

2024년 내부통제체계를 통한 자체 정보보안 감사 결과보고

2024. 8.



한국산림복지진흥원
Korea Forest Welfare Institute

목 차

I. 감사실시 개요	1
1. 감사배경 및 목적	1
2. 감사대상 및 감사중점	1
3. 감사실시 과정	2
4. 감사결과 처리	3
II. 감사대상 주요 현황	3
1. 감사 환경분석	3
2. 감사대상 현황	4
III. 감사결과	5
1. 총 평	5
2. 감사결과 총괄	5
3. 감사결과 처분요구	6
4. 내부통제 관련 성과	7
5. 감사결과 지적사항	8
[붙임] 감사결과 처분요구서	10

I. 감사실시 개요

1. 감사배경 및 목적

「2024년도 연간 감사계획」, 「2024년 상반기 내부통제체계에 의한 자체 정보보안 감사계획」(이하, “정보보안 감사”라 한다)에 따라 실질적인 리스크 식별과 제도 개선을 바탕으로 진흥원의 내부통제가 활성화되고 지속 발전할 수 있도록 감사를 추진하였다.

코로나19 시기의 신규입사자 급증과 대대적인 조직개편으로 인한 업무 공백이나 착오 등을 최소화하기 위하여 지적보다는 현지시정 및 교육을 통한 “일이 되게 하는 감사”로 추진하였다.

특히 내부통제의 중요성이 강조됨에 따라 감사활동을 통해 본원 주요 부서와 현장에서 내부통제기능이 정상적으로 작동할 수 있도록 지속가능 경영 여건 보장을 감사 목적으로 설정하였다.

2. 감사대상 및 감사중점

감사대상은 본원과 소속기관 임직원(계약직 직원 포함)을 감사 대상으로 설정하였으며, 감사 대상 기간은 2023년 10월부터 2024년 7월까지로 정하였다.

이번 자체 정보보안 감사에서는 진흥원 내부통제체계를 활용하여 2차 방어선인 정보보안팀에서는 정보보호시스템을 통해 임직원의 PC보안 준수와 개인정보 보호 관리실태 등을 원격 감사를 실시하고, 3차 방어선인 청렴윤리 감사실에서는 2차 방어선에서 식별된 문제점에 대해 감사처분 및 업무 개선 등의 감사 처분을 실시하였다.

한편, 현장 감사의 경우 국정원의 정보보안 평가 체크리스트 등을 활용하여 외부 기준에 충족할만한 정보보안 및 개인정보보호가 이뤄지는지를

확인하였다.

정보보안 감사의 중점점검 세부 사항은 아래와 같다.

- ▶ 출처, 유통경로 및 제작자가 불분명한 응용프로그램 설치 유무
- ▶ 인터넷 파일공유·메신저·채팅 등 업무상 불필요한 프로그램 설치 유무
- ▶ 인터넷 PC 문서편집 프로그램 무단 설치, 온라인 문서편집 사이트 이용 유무
- ▶ 음란, 도박, 증권, 가상화폐 거래소, 게임, 웹툰, 인터넷 소설, 인터넷 우회 접속 등 업무와 무관한 사이트 지속적으로 접속 유무
- ▶ 개인정보 보호조치(암호화, 삭제) 장기간 미실시 유무
- ▶ 개인정보 및 중요 업무자료 무단 반출(저장매체, 이메일 등 전송) 유무
- ▶ 그 외 정보보안 기본지침 '[별표3] 위규자 처리 세부기준'에서 정한 위규사항

3. 감사실시 과정

2024. 7. 22. (월) 정보보안 감사 계획을 수립하고, 2024. 7. 22. (월) 정보보안팀에 원격(온라인) 점검 결과 자료를 요청하였다. 원격(온라인) 점검은 2024. 7. 22. (월)부터 7. 26. (금) 까지 1주간 실시하였고, 현장 점검은 원격 점검과 병행하여 2024. 7. 29. (월) 부터 8. 2. (금) 까지 1주간 실시하였다.

2024. 7. 22. (월) 정보보안팀에서는 원격(온라인) 점검 결과자료를 제출하였으며, 2024. 7. 29. (월)부터 8. 2. (금)까지 자료 분석 및 사실관계 확인 등 진행하였다.

<2024년 정보보안 감사 실시 개요>

- 감사기간: 총 10일
 - 원격점검: '24. 7. 22.(월) ~ 7. 26.(금) / 현장점검: '24. 7. 26.(월) ~ 8. 2.(금)
- 감사범위: '23. 10. 1. ~ '24. 7. 31.까지 임직원의 정보보안 준수 및 개인정보보호 실태
- 감사인원: 9명 (감사반장 청림윤리감사실장 1명, 감사담당자 2명, 감사지원 6명)
- 감사대상: 본원 및 소속기관 임직원

4. 감사결과 처리

감사원 「공공감사기준」 제28조에 따른 감사보고서에 필요한 사항을 포함하였고, 제출된 원격 점검 결과를 본원 정보보안 분야 내부통제 기능인 정보보안팀과 의견을 나누었다. 이를 통해 지적·개선 사항을 검토하고, 비상임감사의 보고를 거쳐 2024. 8. 12.에 자체 정보보안 감사 결과를 최종 확정하였다.

Ⅱ. 감사대상 주요 현황

1. 감사 환경 분석

1) 대외 환경

진흥원은 위탁집행형 준정부기관으로서 정부의 정보보안 및 개인정보 보호 관련 제규정 등을 준수 의무를 가지며, 국가정보원에서 실시하는 정보보안 평가 등을 통해 준수 정도를 평가받는다.

2) 대내 여건

진흥원은 산림복지시설(소속기관)의 운영을 통해 국민에게 산림복지 서비스를 제공하고 있는데, 효과적인 산림복지프로그램 제공 및 안전보장을 위한 여행자 보험 가입 등의 사유로 방문 고객의 동의하에 개인정보를 수집·관리하고 있다. 진흥원은 19개의 소속기관을 운영하고 있는데 전국에 산재해 있어 직원이 정보보안을 준수하고 있는지에 대해 현장 관리가 어려워 내부통제가 곤란한 여건이다.

한편, 진흥원은 '16년 개원 후 운영시설의 지속 확대로 3년 미만의 신규직원이 전국의 소속기관에 배치되었으며, 이중 30대 미만 직원의 비율이 70% 수준으로 젊은 조직이다.

3) 시사점

진흥원은 준정부기관에 걸맞는 수준의 정보보안 인프라 구축하여 전사적 정보보안시스템을 마련해야 하고, 기관 특성상 다수의 개인정보를 수집·관리 하기에 직원의 정보보안 및 개인정보 보호 의식도 지속 제고하여야 한다.

한편, 업무 지적이 아닌 현지 교육·업무 개선을 통해 업무 중 시행 착오를 최소화하고 위반 사항을 사전 예방하는 감사가 필요한 실정이다.

4) 감사 목적

이러한 시사점을 반영하여 자체 정보보안 감사를 통해 정보보안 관리 체계를 마련하고 효율적인 정보보안이 이루어질 수 있도록 규정 및 제도를 개선하며, 직원의 정보보안 수준 및 개인정보 보호 인식을 향상시키고 끝으로 대외 정보보안 정책 기조에 동참하여진흥원의 지속가능 경영 여건을 보장하는데 감사 목적이 있다.

2. 감사대상 현황

진흥원은 치유원(1기관), 숲체원(7기관), 치유의숲(10기관), 연구개발센터(1기관), 추모원(1기관)으로 편성되어 있고, 본원을 포함한다.

분류		본원	치유원 (1)	연구개 센터 (1)	숲체원(7)							치유의숲(10)										추모원 (1)	유동정원	기타	총 합계	
구분	기관명				본원	산림치유원	연구개 센터	홍성	칠곡	장성	청도	대전	춘천	나주	양평	대관령	김천	제천	예산	대운산	곡성					화순
인원수 (명)	정원	124	73	20	42	28	26	20	24	29	25	5	5	4	4	4	5	4	3	3	2	2	4	3	3	462
	현원	122.5	69.5	16	39	25	23	17	21.5	26	21	4	4	4	4	4	3	3	2	3	2	0	4	0	3	420.5

Ⅲ. 감사결과

1. 총 평

진흥원은 2023년 11월에 기관의 활동에서 발생할 수 있는 준법 정책 및 리스크 대응체계가 효과적으로 운영되고 있는지 평가하는 규범준수경영시스템(ISO37301) 인증을 취득하여 내부통제 사각지대를 식별하고 개선점을 도출하는 등 경영관리와 사업 전반에 대한 리스크 예방에 노력하였다.

연간 감사 목표에 따른 추진전략 및 실행과제를 이행하고자 대내외 환경 분석 기반의 2024년 자체 정보보안 감사 추진 방향을 설정하고, 진흥원 임직원에 대한 자체 정보보안 감사를 실시하였다. 그 결과, 고의·중과실 사항은 없었고, PC바이러스 탐지에 따른 삭제 등 3건의 결함사항을 식별하여 개선 조치를 실시하였다.

본 자체 정보보안 감사를 통해 드러난 문제점과 개선사항은 적절한 조치가 이루어지도록 지속 관리하여 진흥원 전반에 정보보안 및 개인정보 보호가 강화되도록 노력할 예정이다.

2. 감사결과 총괄

지적사항 3건(개선 3건)을 확인하여 감사 조치하였음.

(단위: 건, 천원, 명)

처분요구			행정상조치 (기관)					재정상조치 (금액)		신분상조치 (인원)		현지 처분	적극 행정 면책	모범 사례
건수	금액	인원	주의 경고	시정	개선	권고	통보	시정 (금액)	지급	징계 문책	주의 경고			
3	-	-	-	-	3	-	-	-	-	-	-	-	-	-

3. 감사결과 처분요구

(단위: 건, 천원, 명)

구분	연번	지적사항	관계기관	처분요구		
				행정상 (기관)	재정상 (천원)	신분상 (명)
지적 사례	1	PC바이러스 탐지에 따른 삭제 처리	한국 산림 복지 진흥원	개 선	-	-
	2	업무용 PC로 업무와 무관한 비인가 사이트 접속 차단	한국 산림 복지 진흥원	개 선	-	-
	3	보안취약버전 소프트웨어에 대한 삭제 및 업그레이드 등 조치	한국 산림 복지 진흥원	개 선	-	-

4. 내부통제 관련 성과

2024년 자체 정보보안 감사에서는 감사원에서 요구하는 수준의 내부통제 활동이 잘 이루어지고 있는지에 주안점을 두고 감사를 추진하였다. 특히, 정보보안 분야의 3차 방어선을 구축하여 1차 방어선(현업부서)에서는 정보보안·개인 정보 보호 매뉴얼을 통해 자율 통제를 하였고, 2차 방어선(정보보안 총괄부서)에서는 진흥원의 정보보호시스템을 통해 임직원의 PC보안 준수 및 개인정보 보호 관리실태 등을 원격 점검을 실시하였으며, 3차 방어선(감사 부서)에서는 2차 방어선(정보보안 총괄부서)에서 식별된 문제점에 대해 개선 등 조치를 하였다.

이에 다음과 같이 내부통제시스템이 정상적으로 작동하는데 기여하는 대표적인 성과를 달성하였다.

① PC바이러스 탐지에 따른 삭제 처리

정보보안팀은 임직원이 업무 용도로 사용하는 업무망PC 및 인터넷망 PC가 랜섬웨어 및 트로이목마 등 PC바이러스에 감염되었는지를 탐지하여 총 32건(업무망PC 9건, 인터넷망PC 23건)을 즉시 삭제조치 완료

② 업무용PC로 업무와 무관한 비인가 사이트 접속 차단

정보보안팀은 [별표]와 같이 유해사이트 자동 차단시스템에서 차단되지 않은 업무 무관 인터넷사이트 21건을 발굴하여 임직원이 업무용PC로 접속 하지 못하도록 차단 조치 완료

5. 감사결과 지적사항

① PC바이러스 탐지에 따른 삭제 처리 【개선】

- 「정보보안 기본지침」 제22조 제7항에서는 본원 및 소속기관의 정보 보안담당자는 업무용 단말기(PC, 노트북 등) 운용현황을 파악하여 관리하고, 해킹 프로그램 및 웜·바이러스 감염 여부를 정기적으로 점검토록 함
- 정보보안팀은 임직원이 업무 용도로 사용하는 업무망PC 및 인터넷망PC가 랜섬웨어 및 트로이목마 등 PC바이러스에 감염되었는지를 탐지하여 총 32건(업무망PC 9건, 인터넷망PC 23건)을 즉시 삭제조치 완료

➔ 임직원이 사용하는 업무용PC가 PC바이러스에 감염되지 않도록 지속적으로 관리를 철저히 할 것을 당부 (개선 완료)

② 업무용PC로 업무와 무관한 비인가 사이트 접속 차단 【개선】

- 진흥원 「정보보안 기본지침」 제21조의2 제2항에서는 기관의 인터넷망의 효율적인 운영관리 및 악성코드 유입차단을 위하여 게임·음란·도박 등 업무와 관련이 없는 인터넷 이용을 차단
- 정보보안팀은 [별표]와 같이 유해사이트 자동 차단시스템에서 차단되지 않은 업무 무관 인터넷사이트 21건을 발굴하여 임직원이 업무용PC로 접속하지 못하도록 차단 조치 완료

➔ 임직원이 업무용PC를 통해 업무와 무관한 비인가 사이트를 접속하지 못하도록 차단하는 조치할 것(개선 완료)

③ 보안 취약버전 소프트웨어에 대한 삭제 및 업그레이드 등 조치 【개선】

- 진흥원 「정보보안 기본지침」 제14조 제2항에서는 정보보안팀의 정보 보안담당자는 임직원이 사용하는 PC에 소관 정보통신망 악성코드 감염 여부, 정보시스템 보안 취약점 점검 등 정보보안 업무 전반에 대하여 보안 진단을 주기적으로 실시하여야 함.
- 정보보안팀은 업무 용도로 사용하는 업무망PC 및 인터넷망PC에 설치된 소프트웨어에 대해 구(舊) 버전 사용 중이거나, 최신 보안 업데이트를 하지 않은 등 보안에 취약한 108건을 식별하고 삭제 및 버전 최신화 등의 필요 조치를 실시

➔ 임직원이 사용하는 업무용PC에 설치된 소프트웨어에 대해 버전 등을 최신화하여 보안 취약점이 발생하지 않도록 지속적으로 점검할 것 (개선 완료)